7-апта
Практикалық жұмыс

GadgetStore жобасы

Тәуекелдер тізілімі, STRIDE қауіптер моделі және сәйкестік чек-парағы

Орындаушы	Топ	Талдау күні
Зулпыхаров Ерасыл	АЖ-43	15.10.2026

Мақсат: жобаның техникалық, деректерге қатысты және басқарушылық тәуекелдерін анықтап, оларды нақты бақылау белгілері мен жоспарланған әрекеттерге айналдыру.

Нәтиже	Құрамы
RAID-журнал	24 тәуекел + 4 болжам + 4 мәселе + 3 тәуелділік
Қауіптер моделі	6 STRIDE санаты, 10 қауіп, 2 сенім шекарасы
Сәйкестік	5 дерек санаты және 12 бақылау тармағы
Бэклог	Жауаптысы, мерзімі, қабылдау критерийлері бар 3 тапсырма
Тексеру дәлелі	Trivy, Gitleaks, API тесті, файлдардың SHA-256 тізімі

Мәртебе: оқу есебі және тәуекелдерді төмендету жоспары. Түзетулер бэклогқа енгізілді, бірақ осы жұмыста сайт коды өзгертілген жоқ. Командалық талқылаудың нақты өткені расталмаған; төменде бір орындаушыға арналған pre-mortem талдауы берілген.

Threat Dragon JSON ресми v2 схемасымен тексерілді. Браузердегі импортты тексеру URL анықтау шектеуіне байланысты орындалмады; импорт қадамдары соңында берілген.

1. Ауқым және pre-mortem

Тексеру нысаны: HTML/CSS/JavaScript интерфейсі, server.cjs Node сервері, SQLite тапсырыс/қор/жазылым деректері, Docker конфигурациясы және бөлек белгіленген legacy Flask файлдары. Қазіргі Node серверінің әдепкі адресі - 127.0.0.1:5000; ашық интернетке жарияланғаны расталмаған.

Pre-mortem сұрағы: «Жария пилот пен оқу жобасын тапсыру сәтсіз аяқталды. Оған не себеп болуы мүмкін?» Талдау форматы: код пен конфигурацияны жеке қарап шығу; нәтижесі - R01-R24. Қатысушы ретінде тек Зулпыхаров Ерасыл көрсетілді. Команда өткізген сессияның хаттамасы ойдан құрастырылған жоқ.

Бағыт	Сәтсіздік сценарийі	Тәуекелдер
Қауіпсіздік	Сенімсіз профиль, жалған тапсырыс, артық құқық	R01-R03, R06-R09, R12-R14, R24
Құпиялық	PII артық сақталады, келісім/жою дәлелі жоқ	R04-R05, R16, R22
Үздіксіздік	БҚ жоғалады, сервер тоқтайды, тәуелділік өзгереді	R10-R11, R15, R21, R23
Жоба басқаруы	Бір адам, әлсіз бағалау, кеш шешім, scope өсуі	R17-R20

Бағалау ережесі

P - келесі 4 аптадағы және жоспарланған жария пилоттағы ықтималдықтың сараптамалық деңгейі: 1 өте сирек; 2 төмен; 3 мүмкін; 4 ықтимал; 5 өте ықтимал. Бұл өлшенген жиілік немесе дәл пайыз емес. I - ең үлкен ықтимал әсер: 1 ұсақ UI ақауы; 2 бір күнге дейінгі кідіріс; 3 бірнеше күндік үзіліс; 4 негізгі функция/мерзімнің елеулі бұзылуы; 5 сезімтал деректің ашылуы не қалпына келмейтін жоғалту.

Баға = P × I. 15-25: жоғары, 8-14: орташа, 1-7: төмен. Бағалар қазіргі бақылаулар ескерілгеннен кейін, жоспарланған шаралар іске асырылғанға дейін берілген. Қалдық бағалар - тек мақсат; тексерілмей төмендетілмейді.

Барлық тәуекелдердің иесі - Зулпыхаров Ерасыл. Күйі - ашық. Жоғары бағалы тәуекелді 16.10.2026 бастап әр жұмыс күні; қалғанын көрсетілген қайта қарау күні тексеру. Триггер іске қосылса жоспарлы күнді күтпей әрекет ету. Иесі мен бақылау мерзімі әр жазбада қайталанған.

Бар бақылаулар: сервер бағаны клиенттен алмайды; тауар/сан тексеріледі; SQLite транзакциясы қолданылады; статикалық файлдарға allowlist бар; Origin бар болса салыстырылады. Бұлар қауіптің белгілі бөлігін азайтады, бірақ толық аутентификация немесе abuse қорғанысы емес.

2. Тәуекелдер тізілімі · 1-4

R01 · Демо-кіруді нақты аутентификация деп қабылдау

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: Браузердегі кіру жалаушасы өзгертіледі; болашақ жеке кабинетке сенімсіз негіз болады.

Негіз: script.js:209-217; пароль серверде тексерілмейді.

Триггер: Жеке тапсырысты оқу API-і жергілікті жалаушаға сүйеніп қосылса.

Стратегия: Болдырмау. Жауап жоспары: Серверлік сессия мен әр ресурсқа рұқсат тексеруін енгізу; әзірге демо режимін анық белгілеу.

R02 · Профиль арқылы DOM XSS

P=3; I=5; P×I=15 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 16.10.2026.

Сценарий: Профиль мәндері innerHTML ішіне экрандаусыз түседі; зиянды мән сақталса, сол origin деректері оқылуы мүмкін.

Негіз: script.js:463-475,1206-1214; бұл қашықтан шабуылдың дәлелі емес.

Триггер: Профиль мәні HTML элементіне айналатын қауіпсіз тест қайталанса.

Стратегия: Төмендету. Жауап жоспары: textContent/value арқылы шығару, қауіпті HTML-ді жою; CSP қосып, DOM тестін өткізу.

R03 · Карта деректерінің браузерде сақталуы

P=4; I=5; P×I=20 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 16.10.2026.

Сценарий: Демо форма карта нөмірі мен мерзімін localStorage-ға жазады; ортақ компьютер не XSS арқылы ашылуы мүмкін.

Негіз: script.js:1128-1136; нақты карта деректері тексерілген жоқ.

Триггер: localStorage профилінде cardNumber не cardExpiry бос емес болса.

Стратегия: Болдырмау. Жауап жоспары: Карта өрістерін алып тастау; бұрынғы кілттерді тазалау миграциясы; онлайн төлем болса провайдер токенін ғана сақтау.

R04 · Тапсырыс деректеріне құрылғыдан рұқсатсыз қол жеткізу

P=3; I=5; P×I=15 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: Аты-жөн, телефон, мекенжай SQLite пен браузер тарихында сақталады; файл/браузер профиліне қол жеткізу құпиялықты бұзады.

Негіз: server.cjs:54-55; script.js checkout және gadgetStoreOrders.

Триггер: Ортақ Windows аккаунты қолданылса немесе БҚ көшірмесі қорғалмаған жерге шықса.

Стратегия: Төмендету. Жауап жоспары: Браузерде ең аз мәлімет қалдыру; NTFS рұқсаттары, дискті шифрлау, қорғалған backup; қолжетімділікті тексеру.

2. Тәуекелдер тізілімі · 5-8

R05 · Келісім мен сақтау мерзімінің болмауы

P=4; I=4; P×I=16 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: Құпиялық сілтемесі бос, жою мерзімі жоқ; нақты деректерді өңдеудің негізін дәлелдеу қиын.

Негіз: index.html:292; orders/subscribers үшін TTL немесе жою маршруты жоқ.

Триггер: Нақты клиент дерегі саясат пен келісім нұсқасы бекітілмей жиналса.

Стратегия: Төмендету. Жауап жоспары: Саясат, мақсат, келісім жазбасы және жою рәсімін дайындау; бекіткенге дейін синтетикалық дерек қолдану.

R06 · Жалған тапсырыспен қорды тауыстыру

P=4; I=4; P×I=16 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: API әр жарамды тапсырыста қорды азайтады; жиілік шегі мен тапсырысты растау жоқ. Ашық орналастыруда теріс пайдалану ықтимал.

Негіз: server.cjs:32-59; Origin тексеруі боттан қорғамайды.

Триггер: Бір IP-ден 60 секундта 5-тен көп тапсырыс немесе қордың 10 минутта 30% азаюы.

Стратегия: Төмендету. Жауап жоспары: Жиілік шегі, уақытша бронь және растау; шекті асқанда 429; күдікті броньды босату.

R07 · Қайталанған POST екі тапсырыс жасайды

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: Байланыс үзілгеннен кейін қайталау жаңа UUID жасайды; бір сатып алу екі рет есептеледі.

Негіз: server.cjs:54; idempotency key өңделмейді.

Триггер: Бір клиенттің бірдей себеті 60 секунд ішінде екі ID алса.

Стратегия: Төмендету. Жауап жоспары: Idempotency-Key-ді серверде бірегей сақтау; бір кілтке бір тапсырыс; қайта жіберу тесті.

R08 · Инцидентті дәлелдейтін аудиттің жоқтығы

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Кім қандай операция жасағанын анықтау қиын; тапсырыс жазбасы толық қауіпсіздік аудиті емес.

Негіз: server.cjs тек іске қосылуды console.log арқылы жазады.

Триггер: Тестілік бас тартудың request ID және уақыт белгісі журналдан табылмаса.

Стратегия: Төмендету. Жауап жоспары: Құпиясыз құрылымдық аудит; request ID, нәтиже, уақыт; журналға рұқсат пен сақтау мерзімін бекіту.

2. Тәуекелдер тізілімі · 9-12

R09 · Қате жауабымен ішкі ақпарат ашылуы

P=2; I=3; P×I=6 (төмен). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Шикі error.message клиентке беріледі; болашақ SQLite/файл қатесі ішкі детальдарды ашуы мүмкін.

Негіз: server.cjs:70 маңындағы жалпы catch.

Триггер: 500/400 жауапта файл жолы, SQL немесе ішкі стек туралы мәлімет көрінсе.

Стратегия: Төмендету. Жауап жоспары: Клиентке тұрақты қате коды; ішкі мәліметті қорғалған журналда request ID-мен сақтау.

R10 · SQLite жоғалғанда қалпына келмеу

P=3; I=5; P×I=15 (жоғары). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Автоматты сақтық көшірме мен restore хаттамасы расталмаған; диск бұзылса тапсырыстар жоғалады.

Негіз: data/store.sqlite; docker-compose.yml named volume резервтік көшірме емес.

Триггер: Соңғы тексерілген backup жасы 24 сағаттан асса немесе restore 30 минуттан ұзақ болса.

Стратегия: Төмендету. Жауап жоспары: SQLite backup API/келісімді snapshot; бөлек қорғалған көшірме; оқшау ортада restore және integrity_check.

R11 · Сервер баяулауы және ақаудың кеш анықталуы

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 26.10.2026.

Сценарий: Синхронды SQLite бүкіл процесті бөгей алады; контейнерде HEALTHCHECK жоқ, restart саясаты тірі, бірақ жауап бермейтін процесті анықтамайды.

Негіз: server.cjs DatabaseSync; Trivy DS-0026 (LOW), Dockerfile.

Триггер: Бос диск 20%-дан аз, health 3 рет қатарынан өтпесе немесе p95 5 минут бойы 1 секундтан көп.

Стратегия: Төмендету. Жауап жоспары: HEALTHCHECK, диск/латенттілік метрикалары, сұрау лимиті; жүктеме шегін белгілеу және қалпына келтіру рәсімі.

R12 · Legacy кодтағы тұрақты БҚ паролі

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 16.10.2026.

Сценарий: Архивтік Flask конфигурациясында пароль бар; қайта қолданылса БҚ қолжетімділігі бұзылады.

Негіз: app.py:13; құпия мәні есепте жарияланбайды.

Триггер: Бұл пароль нақты ортада қолданылғаны расталса немесе файл жария репозиторийге түссе.

Стратегия: Болдырмау. Жауап жоспары: Қолданылған болса дереу ауыстыру; env/secret store; legacy кодты бөлек архивке шығару; secret scan.

2. Тәуекелдер тізілімі · 13-16

R13 · Ескі Flask серверін қателесіп іске қосу

P=2; I=5; P×I=10 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: static_folder="." және кең CORS конфигурациясы жобаның артық файлдарын ашуы мүмкін.

Негіз: app.py; қазіргі Dockerfile Node серверін іске қосады.

Триггер: Іске қосу командасында app.py қолданылса немесе Flask 0.0.0.0:5000 тыңдаса.

Стратегия: Болдырмау. Жауап жоспары: Бір ресми іске қосу жолы; legacy файлдарын deployment жинағына қоспау; жария файлдар allowlist тесті.

R14 · Контейнердің root атынан орындалуы

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Қолданба бұзылған жағдайда контейнер ішіндегі артық құқық залалды ұлғайтады.

Негіз: Dockerfile: USER нұсқауы жоқ.

Триггер: Контейнер ішіндегі id -u нәтижесі 0 болса.

Стратегия: Төмендету. Жауап жоспары: USER node, volume рұқсаттарын сәйкестендіру, қажетсіз capabilities алып тастау және smoke test.

R15 · Тәуелділіктердің бақыланбай жаңаруы

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Docker тегінің digest-і бекітілмеген, legacy Python пакеттері көбіне нұсқасыз; қайталанатын жинақ пен CVE бақылауы әлсірейді.

Негіз: Dockerfile node:24-alpine; requirements.txt; Node runtime npm тәуелділігі жоқ.

Триггер: Жинақ digest-і келісімсіз өзгерсе немесе қолданыстағы тәуелділікте High/Critical CVE табылса.

Стратегия: Төмендету. Жауап жоспары: Белсенді және legacy тізімдерді бөлу, lock/digest, SBOM және жоспарлы CVE тексеру.

R16 · Сыртқы CDN істен шығуы немесе мазмұн өзгеруі

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 26.10.2026.

Сценарий: Қаріп, стиль және сурет сыртқы қызметтерге тәуелді; қолжетімділік пен сыртқы желілік метадерек мәселесі бар.

Негіз: index.html:8-12; integrity бос; Pexels суреттері.

Триггер: CDN сұрауы 5xx берсе немесе бақылау хэші бекітілген мәнмен сәйкес келмесе.

Стратегия: Төмендету. Жауап жоспары: Қажет ресурсты лицензиясымен бірге локал сақтау; сыртқы ресурс қалса SRI және CSP бағалау.

2. Тәуекелдер тізілімі · 17-20

R17 · Бір орындаушыға тәуелділік

P=4; I=3; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Жобаның білімі мен барлық міндеті бір адамда; қолжетімсіздік тапсыруды кешіктіреді.

Негіз: Жоба орындаушысы: Зулпыхаров Ерасыл.

Триггер: Орындаушы 2 жұмыс күні жұмыс істей алмаса немесе апталық жоспардың 20% орындалмаса.

Стратегия: Төмендету. Жауап жоспары: README, іске қосу және restore нұсқаулығы; тапсырмаларды шағын ету; мерзім резервін қарау.

R18 · Мерзімді оптимистік бағалау

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Бұрынғы зертханада қолданылған мысал throughput нақты өндірістік тарих емес; болжам қателесуі мүмкін.

Негіз: output/lab6 материалдары; тәуекел бағалары да сараптамалық.

Триггер: Екі апта қатарынан аяқталған жұмыс жоспардың 80%-нан төмен болса.

Стратегия: Төмендету. Жауап жоспары: Нақты аяқталу күндерін жинау; ықтималдық болжамын қайта есептеу; scope-ты қысқарту.

R19 · Тапсырыс берушінің шешімі кешігуі

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 19.10.2026.

Сценарий: Каталог, жеткізу ережесі немесе талап бекітілмесе қайта жасау қажет.

Негіз: 5-апта жоспарының сыртқы растаулары; нақты жауаптар тексерілмеген.

Триггер: Бекітуге берілген сұрақ 2 жұмыс күні жауапсыз қалса.

Стратегия: Төмендету. Жауап жоспары: Шешімдер журналын жүргізу; жауаптың шекті күнін белгілеу; оқытушымен scope келісу.

R20 · Жұмыс көлемінің бақылаусыз ұлғаюы

P=4; I=3; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Лабораторияға қоса төлем, толық кабинет немесе deployment қосылса уақыт жетпейді.

Негіз: Қазіргі тапсырма - 7-апта артефактілері; сайтты жетілдіру кейінге қалдырылған.

Триггер: Жаңа міндет ағымдағы жоспарға бағалаусыз енгізілсе.

Стратегия: Болдырмау. Жауап жоспары: Өзгеріс өтінімі, құны/мерзімі; жаңа функцияны кейінгі бэклогқа бөлу.

2. Тәуекелдер тізілімі · 21-24

R21 · Каталог пен БҚ көшірмесінің сәйкессіздігі

P=3; I=3; P×I=9 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 26.10.2026.

Сценарий: INSERT OR IGNORE бұрын бар өнімді жаңартпайды; products.json түзетілгенде ескі баға БҚ-да қалуы мүмкін.

Негіз: server.cjs:15-16; сервер бағаны БҚ-дан есептейді.

Триггер: Файлдағы және API-дегі бір өнімнің бағасы не атауы өзгеше болса.

Стратегия: Төмендету. Жауап жоспары: Нұсқаланған migration/каталог импортын жасау; өзгеріс алдында snapshot және салыстыру.

R22 · AI қосылғанда деректі сыртқа беру

P=2; I=4; P×I=8 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 26.10.2026.

Сценарий: Болашақ чатботқа тапсырыс PII-ін жіберу келісім мен деректер тасымалы талабын бұзуы мүмкін. Қазіргі жүйеде AI іске қосылмаған.

Негіз: requirements.txt-та openai атауы ғана бар; белсенді серверде AI шақыруы жоқ.

Триггер: AI API шақыруы немесе клиент дерегін prompt-қа қосатын код пайда болса.

Стратегия: Болдырмау. Жауап жоспары: Жеке privacy/threat review, PII азайту, AI екенін хабарлау, адамға ауысу; провайдер шартын тексеру.

R23 · Қауіпсіздік регрессиялары байқалмауы

P=3; I=4; P×I=12 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: Функционалдық тесттер XSS, privacy, restore және abuse сценарийлерін толық жаппайды.

Негіз: tests/api.cjs және қолмен код талдауы.

Триггер: Қауіпсіздік өзгерісі acceptance тестсіз қабылданса немесе CI тесті өтпесе.

Стратегия: Төмендету. Жауап жоспары: Бэклогтағы қабылдау критерийлерін тестке айналдыру; merge/release алдында тексеру.

R24 · Жария орналастыру конфигурациясының қателігі

P=2; I=5; P×I=10 (орташа). Иесі: Зулпыхаров Ерасыл. Күйі: ашық. Қайта қарау: 22.10.2026.

Сценарий: HOST=0.0.0.0, ашық порт және TLS жоқ орта бірге қолданылса дерек пен API сыртқа шығады.

Негіз: Node әдепкі loopback; Docker ішінде 0.0.0.0, compose host порты loopback.

Триггер: 127.0.0.1 орнына 0.0.0.0 host port немесе HTTP арқылы сыртқы қолжетімділік анықталса.

Стратегия: Төмендету. Жауап жоспары: TLS reverse proxy, нақты trusted origin және firewall; сыртқы probe; жариялауға дейін тексеру.

3. Ең жоғары 5 тәуекел · 1-2

R03 · Карта деректерінің браузерде сақталуы

Бастапқы баға: 4×5=20. Иесі: Зулпыхаров Ерасыл. Триггер: localStorage профилінде cardNumber не cardExpiry бос емес болса.

Себеп-салдар: Демо өріске пайдаланушы шынайы карта нөмірін енгізеді. Браузерді бөлісетін адам не сол origin-де орындалған скрипт оны оқуы мүмкін. Ақпараттың нақты жиналғаны туралы дәлел жоқ.

Алдын алу және тексеру: B7-01: өрістерді, сақтау кодын және ескі карта атрибуттарын тазалау. Қабылдау: синтетикалық профильден карта өрістері жоғалады, интерфейс қайта ашылғанда қайтып келмейді.

Оқиғаға жауап: Триггер болса нақты дерек енгізуді тоқтату; профиль көшірмесін таратпау; ашылу ауқымын анықтау. Мақсатты қалдық баға: 1×5=5.

R05 · Келісім мен сақтау мерзімінің болмауы

Бастапқы баға: 4×4=16. Иесі: Зулпыхаров Ерасыл. Триггер: Нақты клиент дерегі саясат пен келісім нұсқасы бекітілмей жиналса.

Себеп-салдар: Тапсырыс пен email жиналады, бірақ мақсат, келісім нұсқасы, кері қайтару және жою рәсімі тіркелмейді. Бұл кодтан көрінетін дайындық алшақтығы; құқықтық сәйкестік аудиті аяқталды деген сөз емес.

Алдын алу және тексеру: B7-01: саясат, келісім дәлелі және retention жобасы; нақты дерекпен пилотқа дейін оператор мен сақтау орны бекітіледі.

Оқиғаға жауап: Триггер болса нақты деректермен пилотты тоқтату; дерек картасын түгендеу; заңды негізді қайта қарау. Қалдық мақсат: 2×4=8.

3. Ең жоғары 5 тәуекел · 3-4

R06 · Жалған тапсырыспен қорды тауыстыру

Бастапқы баға: 4×4=16. Иесі: Зулпыхаров Ерасыл. Триггер: Бір IP-ден 60 секундта 5-тен көп тапсырыс немесе қордың 10 минутта 30% азаюы.

Себеп-салдар: Сайт интернетке ашылғанда автоматты клиент көптеген жарамды тапсырыс жіберіп, қойма қорын броньсыз азайтады. Localhost режимі сыртқы экспозицияны шектейді, бірақ кодта abuse бақылауы жоқ.

Алдын алу және тексеру: B7-02: жиілік шегі және уақытша бронь. 6-шы сұрау 60 секундтық лимитте 429 беруі тиіс; расталмаған бронь белгіленген TTL соңында босайды.

Оқиғаға жауап: Шек бұзылса күдікті клиентті уақытша шектеу, жалған тапсырысты тексеріп қорды қалпына келтіру; PII-ді журналға шығармау. Қалдық мақсат: 2×4=8.

R02 · Профиль арқылы DOM XSS

Бастапқы баға: 3×5=15. Иесі: Зулпыхаров Ерасыл. Триггер: Профиль мәні HTML элементіне айналатын қауіпсіз тест қайталанса.

Себеп-салдар: Профильдегі мәтін HTML контекстіне қойылады. Сол мәнге әсер ете алған субъект профиль ашылғанда DOM-ды өзгерте алады. Бұл талдау сырттан профиль жазудың дәлелденген арнасын көрсетпейді.

Алдын алу және тексеру: B7-01: мәндерді DOM property арқылы енгізу, қауіпті HTML жолдарын қысқарту, CSP. Қабылдау: HTML-ге ұқсас тест мәтіні тек мәтін ретінде көрінеді.

Оқиғаға жауап: Триггер болса қауіпті өрісті уақытша өшіру, зардап шеккен браузер кілттерін тазалау; түзетуді қайта тексеру. Қалдық мақсат: 1×5=5.

3. Ең жоғары 5 тәуекел · 5-5

R04 · Тапсырыс деректеріне құрылғыдан рұқсатсыз қол жеткізу

Бастапқы баға: 3×5=15. Иесі: Зулпыхаров Ерасыл. Триггер: Ортақ Windows аккаунты қолданылса немесе БҚ көшірмесі қорғалмаған жерге шықса.

Себеп-салдар: Тапсырыстың жеткізу деректері серверде және клиенттің жергілікті тарихында қайталанады. Ортақ ОС аккаунты, қорғалмаған архив немесе XSS бір көшірмені ашуы мүмкін; серверде барлық тапсырысты жария оқитын API табылған жоқ.

Алдын алу және тексеру: B7-01 және B7-03: клиентте тек тапсырыс ID/қысқа күй; файлға тек қызмет аккаунты; қорғалған backup; retention рәсімі.

Оқиғаға жауап: Қолжетімсіз ету, қай көшірме ашылғанын анықтау, инцидент журналын жасау; хабарлау міндетін қолданыстағы талап бойынша бағалау. Қалдық мақсат: 2×5=10.

Басымдықты таңдау

Алдымен баға бойынша, тең болғанда нақты дерек жинауға жақындық бойынша таңдалды: R03 (20), R05 (16), R06 (16), R02 (15), R04 (15). R10 да 15 балл; оны шұғылдық жағынан төмендетпейміз және B7-03 құрамында қараймыз.

R10 үшін қалпына келтіру тәртібі

Жазуды тоқтату; бүлінген базаға тиіспей оқшау көшірме алу; соңғы келісімді backup-ты бөлек каталогқа қалпына келтіру; PRAGMA integrity_check және синтетикалық тапсырыс санын тексеру; сервисті ауыстыру; басталу/аяқталу уақытын жазу. RPO ≤24 сағат, RTO ≤30 минут - тексерілетін мақсаттар. WAL режимінде жұмыс істеп тұрған жалғыз .sqlite файлын жай көшіру жеткіліксіз болуы мүмкін; SQLite backup API немесе келісімді snapshot қажет.

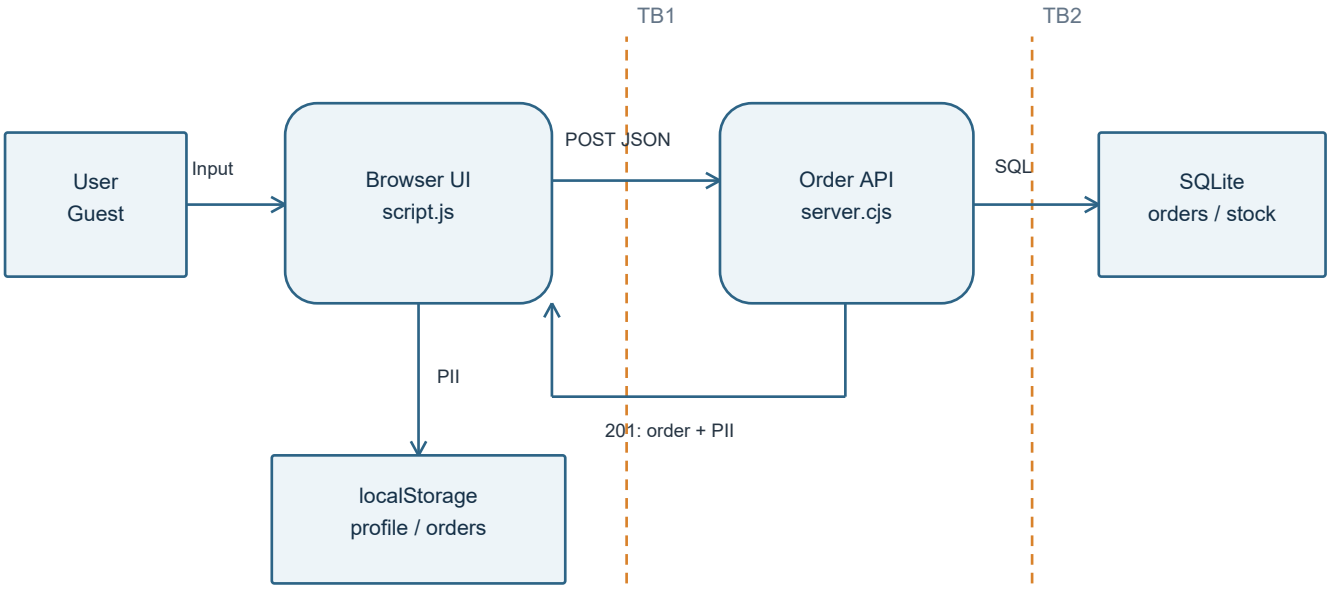
4. RAID: болжам, мәселе, тәуелділік

R бөлімі алдыңғы тізілімде берілді. Төмендегі барлық A/I/D жазбаларының жеке иесі де - Зулпыхаров Ерасыл. Күйі: A - тексеріледі; I - ашық; D - растау күтіледі.

ID / түрі	Жазба	Бақылау / әрекет	Күні
A01 Болжам	Жоба бір орындаушының оқу жобасы.	Топ мүшелері қосылса R17 мен жауаптыларды қайта бөлу.	22.10.2026
A02 Болжам	Бағалар localhost прототипінен жария пилотқа өту сценарийіне берілді.	Пилот ортасы бекітілсе ықтималдықтарды қайта есептеу.	22.10.2026
A03 Болжам	Тексеруде тек синтетикалық деректер қолданылады.	Нақты PII қажет болса чек-парақтың ашық тармақтарын жабу.	19.10.2026
A04 Болжам	RPO 24 сағат, RTO 30 минут - ұсынылатын мақсаттар.	Restore өлшеуі немесе тапсырыс беруші талабы өзгерсе қайта бекіту.	22.10.2026
I01 Мәселе	Карта деректері localStorage-ға жазылады (R03).	B7-01 қабылдау тестімен жабылады.	19.10.2026
I02 Мәселе	Құпиялық сілтемесі #, retention жоқ (R05).	Саясат және жою дәлелі қажет.	19.10.2026
I03 Мәселе	Legacy app.py ішінде тұрақты пароль бар (R12).	Қолданылуын анықтау, қажет болса ауыстыру, secret scan.	16.10.2026
I04 Мәселе	Репозиторийде .git тарихы жоқ.	Gitleaks нәтижесі тек берілген файлдарға қатысты.	22.10.2026
D01 Тәуелділік	Талап пен retention-ды бекітетін тапсырыс беруші/оқытушы.	2 жұмыс күні жауап болмаса шешімдер журналында белгілеу.	19.10.2026
D02 Тәуелділік	ҚР аумағындағы хостинг және backup шарттары.	Нақты дерекпен жария пилот алдында орналасу дәлелін алу.	22.10.2026
D03 Тәуелділік	CDN/қаріп/сурет қызметтері.	Желіні ажыратқанда негізгі бет жарамдылығын тексеру.	26.10.2026

5. STRIDE: тапсырыс деректерінің ағыны

Таңдалған компонент - тапсырысты рәсімдеу мен сақтау. Модель қазіргі іске асыруды көрсетеді; төлем шлюзі, AI және болашақ серверлік жеке кабинет ауқымға кірмейді. Төмендегі сызба JSON моделіндегі ағынның есепке арналған көрінісі, Threat Dragon скриншоты емес.



Белгі	Сенім шекарасы / актив
TB1	Сенімсіз браузер мен сервер арасындағы HTTP JSON. Origin - клиенттің жеке басын растау емес.
TB2	Node процесі мен SQLite файлдары. Файл рұқсаты мен backup қорғанысы операциялық ортаға тәуелді.
Активтер	Тапсырыс PII, қойма қоры/бағасы, браузер профилі, сервер қолжетімділігі.
Ескерту	Карта дерегі checkout API-іне жіберілмейді; localStorage-да сақталады. Серверлік orders тізімін оқитын ашық API жоқ.

GadgetStore_ThreatDragon.json: 12 элемент, 10 қауіп, 6 STRIDE санаты. Әр қауіп Open күйінде; ұсынылған mitigations іске асырылды деп белгіленбеген. Ресми v2 JSON Schema валидациясы өтті.

5.1. STRIDE қауіптері · 1-5

T01 · Spoofing · R06

Автоматтандырылған клиент жалған аты-жөн мен телефон арқылы тапсырыс береді. Guest checkout өздігінен осалдық емес; мәселе abuse бақылауында.

Бақылау: Rate limit, уақытша бронь және растау. Қабылдау: Лимиттен асқан тапсырыс 429; расталмаған бронь босайды.

T02 · Tampering · R02

Профиль мәні innerHTML арқылы DOM-ға енеді.

Бақылау: textContent/value және CSP. Қабылдау: HTML-ге ұқсас мән скрипт/элемент ретінде орындалмайды.

T03 · Tampering · R07

Бір POST қайталанып, екі тапсырыс пен екі қор өзгерісін жасайды.

Бақылау: Idempotency-Key және транзакция. Қабылдау: Бір кілтті қайталау бір ID қайтарады, қор бір рет кемиді.

T04 · Repudiation · R08

Тапсырысты кім және қашан жасағанын қауіпсіздік журналы арқылы байланыстыру мүмкін емес.

Бақылау: Request ID, уақыт, нәтиже, шектеулі аудит. Қабылдау: Синтетикалық сұраудың нәтижесі журналда PII-сіз табылады.

T05 · Information disclosure · R03/R04

Браузер профилін немесе сол origin-ді иеленген субъект карта/тапсырыс деректерін оқиды.

Бақылау: Карта өрістерін жою, клиент дерегін азайту. Қабылдау: Карта және жеткізу мекенжайы жергілікті сақтауда қалмайды.

Әр қауіптің иесі: Зулпыхаров Ерасыл. Мерзім: байланысты RAID жазбасындағы қайта қарау күні; түзету мерзімі B7-01/B7-02/B7-03 арқылы бақыланады.

5.1. STRIDE қауіптері · 6-10

T06 · Information disclosure · R04

SQLite не backup файлына рұқсат алған адам тапсырыс PII-ін оқиды.

Бақылау: Least privilege, диск/backup қорғауы, retention. Қабылдау: Бөгде ОС аккаунты БҚ мен көшірмені оқи алмайды.

T07 · Denial of service · R06/R11

Жарамды сұраулар тасқыны қорды тауыстырады немесе синхронды БҚ-ны жүктейді.

Бақылау: Rate limit, мониторинг, жүктеме шегі. Қабылдау: Бекітілген тест жүктемесінде p95 <1 секунд; abuse шектеледі.

T08 · Elevation of privilege · R14

Қолданбадағы болашақ код орындау осалдығы root контейнерде артық құқық алады. RCE бар екені дәлелденген жоқ.

Бақылау: Root емес USER, capabilities қысқарту. Қабылдау: Контейнер UID !=0; қажетсіз жүйелік операцияларға рұқсат жоқ.

T09 · Information disclosure · R24

HTTP интерфейсін сыртқы желіге ашқанда тапсырыс дерегі тасымалдау кезінде ашылуы мүмкін.

Бақылау: Жария ортада TLS, trusted origin, firewall. Қабылдау: Сыртқы HTTP PII қабылдамайды; HTTPS сұрауы өтеді.

T10 · Tampering · R21

Файлдағы баға өзгерсе де БҚ ескі нұсқаны пайдаланады.

Бақылау: Нұсқаланған каталог migration және салыстыру. Қабылдау: Бекітілген каталог нұсқасы API нәтижесімен сәйкес.

Әр қауіптің иесі: Зулпыхаров Ерасыл. Мерзім: байланысты RAID жазбасындағы қайта қарау күні; түзету мерзімі B7-01/B7-02/B7-03 арқылы бақыланады.

6. Дербес деректер картасы

Тапсырыс: аты-жөн, телефон, мекенжай, тауарлар, UUID, уақыт

Мақсаты және негізі: Жеткізу және тапсырысты орындау. Ұсыныс: мақсатты келісім, оның мәтіні/нұсқасын тіркеу; заңдағы ерекшелік қолданылса негізін бөлек құжаттау.

Қайда: SQLite orders.payload; көшірмесі браузер gadgetStoreOrders.

Кім қол жеткізе алады: Сервер процесі, файлға рұқсаты бар ОС пайдаланушысы; клиент браузері мен сол origin скрипті.

Сақтау мерзімі: Қазір мерзімсіз. Оқу дерегі: қорғаудан кейін 7 күн ішінде жою; коммерциялық сақтау мерзімін заңды міндеттермен бөлек бекіту.

Профиль: аты, email

Мақсаты және негізі: Демо кабинет. Нақты сәйкестік расталмайды; ерікті енгізу келісім дәлелі ретінде тіркелмеген.

Қайда: gadgetStoreClientUser және gadgetStoreClientProfile localStorage.

Кім қол жеткізе алады: Осы браузер профилі және origin скрипттері.

Сақтау мерзімі: Қазір автоматты жою жоқ. Ұсыныс: профильді жою әрекеті және демо деректі қорғаудан кейін 7 күнде тазалау.

Карта нөмірі мен жарамдылық мерзімі

Мақсаты және негізі: Қазіргі тапсырыс «алған кезде төлеу» режимінде; жинау қажеттілігі жоқ.

Қайда: gadgetStoreClientProfile; серверлік төлем шлюзі жоқ.

Кім қол жеткізе алады: Браузер профилі және origin скрипттері.

Сақтау мерзімі: Ұсыныс: сақтамау; B7-01 арқылы бұрынғы атрибуттарды тазалау.

6. Дербес деректер картасы

Жазылым email және created_at

Мақсаты және негізі: Жаңалық жіберу мақсаты; бөлек келісім мен бас тарту рәсімі қажет. Нақты email жіберу интеграциясы тексерілген кодта жоқ.

Қайда: SQLite subscribers.

Кім қол жеткізе алады: Сервер процесі және БҚ файлына рұқсаты бар ОС пайдаланушысы.

Сақтау мерзімі: Қазір мерзімсіз. Ұсыныс: келісім қайтарылса жою; оқу базасы қорғаудан кейін 7 күн ішінде тазаланады.

IP, User-Agent сияқты желілік метадерек

Мақсаты және негізі: Қаріп/стиль/сурет жүктеу кезінде сыртқы провайдер сұрауды көреді; форма мәндері оларға жіберіледі деген дәлел жоқ.

Қайда: Google Fonts, cdnjs, Pexels инфрақұрылымы; нақты сақтау ережелері бағаланбаған.

Кім қол жеткізе алады: Тиісті провайдерлер; бұл жобада олардың retention-ы басқарылмайды.

Сақтау мерзімі: Белгісіз. Ұсыныс: ресурстарды локал сақтау немесе провайдер шарттарын тексеріп саясатқа енгізу.

Құпиялық және заңнама

ҚР «Дербес деректер және оларды қорғау туралы» заңындағы келісімді дәлелдеу, мақсатқа сай сақтау және үшінші тарапқа/трансшекаралық беру шарттары ескерілді [1]. Деректерді қорғау және жинау қағидалары ҚР аумағында сақтау талабын нақтылайды [2, 3]. Ұсынылған 7 күн - осы оқу жобасының демо дерегін тазалау саясаты; заң белгілеген әмбебап мерзім емес. Нақты оператор, хостинг және қолданылатын заңды ерекшеліктер әлі бекітілмеген.

15.10.2026 күні ресми Әділет іздеу мәтіндері тексерілді. Негізгі толық бетті тікелей ашу timeout берді; сондықтан есеп құқықтық сәйкестік сертификаты емес, анықталған алшақтықтар мен тексерілетін талаптар тізімі ретінде ұсынылады. Нақты дерекпен іске қосу алдында соңғы толық редакцияны қайта тексеру керек.

6.1. Сәйкестік чек-парағы

ID	Бақылау	Күйі / дәлел және әрекет
C01	Деректердің құрамы және мақсаты	Ішінара. DATA кестесі жасалды; карта деректері артық. B7-01.
C02	Өңдеу негізі және келісімді дәлелдеу	Ашық. Саясат мәтіні/келісім нұсқасы/қайтару арнасы жоқ. Нақты дерекпен пилотқа дейін бекіту.
C03	ҚР аумағында сақтау	Расталмаған. Windows жолы географиялық орналасуды дәлелдемейді. Хостинг пен backup орналасуы туралы құжат алу.
C04	Деректерге қолжетімділікті шектеу	Ішінара. Статикалық allowlist бар; ОС рұқсаты, диск шифрлауы және backup рұқсаттары тексерілмеген.
C05	Сақтау мерзімі, жою және субъект сұрауы	Ашық. Жою API/жоспары жоқ; оқу мерзімдері ұсыныс ретінде берілді; коммерциялық мерзім бөлек бекітіледі.
C06	Журналдау және инцидент рәсімі	Ашық. PII-сіз аудит, инцидент иесі, оқиға уақыты және әрекеттер журналы қажет.
C07	Тасымалдау және үшінші тараптар	Ішінара. Қазіргі loopback HTTP; жария ортаға TLS керек. Сыртқы ресурстарды локалдау немесе шарттарын бағалау.
C08	Backup және үздіксіздік	Ашық. RPO 24 сағат / RTO 30 минут ұсынылды; restore өлшеуі әлі жоқ. B7-03.
C09	AI компонентінің бар-жоғы	Қолданылмайды. Белсенді Node/JS ағынында модель шақыруы жоқ. requirements.txt ішіндегі openai атауы жұмыс істейтін AI дәлелі емес.
C10	AI тәуекел санаты және ашықтық	Шартты. AI жоқ болғандықтан санат N/A. Болашақ чатботта transparency міндеті мен ЕО аясы қайта бағаланады; автоматты түрде high-risk деп белгіленбейді.
C11	Құпиялыққа әсерді бағалау	Алдын ала. Негізгі қауіп: карта мен жеткізу дерегінің артық көшірмелері. Формалды privacy review нақты дерек пен deployment бекітілгенде өткізіледі.
C12	Тәуелділік, құпиялар, SBOM	Ішінара. Сканер есептері қосымшада. Сканерден табылмауы қауіптің жоқтығын білдірмейді; legacy және белсенді runtime ажыратылды.

Барлық ашық тармақтың жауаптысы: Зулпыхаров Ерасыл. Негізгі қайта қарау: 19.10.2026; backup/deployment: 26.10.2026. «Ішінара» - бақылаудың бір бөлігі бар; «Расталмаған» - жеткілікті дәлел алынбаған.

6.2. AI және сәйкестік шекарасы

Белсенді GadgetStore жүйесінде AI компоненті анықталмады: server.cjs және script.js ағынында модель шақыруы жоқ. Сондықтан қазіргі AI санаты - N/A. Legacy requirements.txt-тағы openai пакеті оны жұмыс істейтін AI жүйесіне айналдырмайды.

Болашақ өнім кеңесшісі/чатбот қосылса, R22 іске қосылады. Қолданушыға AI-мен сөйлесіп отырғанын айту, жауапқа адам арқылы түзету мүмкіндігін беру және клиент PII-ін prompt-қа жібермеу - жоспарланған бақылаулар. Тауар ұсынатын чатботты тек атауы бойынша high-risk деп белгілеуге негіз жоқ; нақты функция, деректер мен нарық аясы бағаланады.

Еурокомиссияның ресми AI Act парағы бойынша негізгі қолдану және ашықтық талаптарының кезеңі - 02.08.2026; кей жоғары тәуекел санаттарының мерзімдері бөлек [4]. Қазақстандағы оқу жобасына EU AI Act автоматты түрде қолданылады деген қорытынды жасалмайды. ЕО нарығына шығу немесе ЕО-дағы қолдану жағдайы пайда болса, заңның аумақтық аясы мен тиісті міндеттер қайта тексеріледі.

Қорғауға арналған қысқа түсіндірме

«Біздің негізгі активіміз - клиенттің жеткізу деректері мен тауар қоры. Қазіргі сайт localhost режимінде жұмыс істейді, бірақ жария пилотта деректі азайту, қауіпсіз DOM, тапсырыс лимиті, қайталануды болдырмау және backup қажет. Әр қауіпке нақты иесі мен триггер берілді. Жоспарланған шаралар тек қабылдау тестінен өткен соң орындалды деп белгіленеді.»

7. Сканерлер және тексеру дәлелі

Тексеру күні: 15.10.2026. Бастапқы код пен конфигурацияның 20 файлы бөлек snapshot-қа көшірілді; SHA-256 тізімі evidence/source-manifest.json ішінде. Жеке база, backup архиві, суреттер, бұрынғы оқу есептері және уақытша құралдар сканға кірмеді. .git тарихы жоқ, сондықтан commit history тексерілмеді.

Құрал	Нәтиже	RAID байланысы
Trivy 0.76.0	DS-0002 HIGH: root емес USER жоқ	R14
Trivy 0.76.0	DS-0026 LOW: HEALTHCHECK жоқ	R11
Trivy secret scan	Стандартты secret ережелері бойынша 0 нәтиже	Қауіпсіздік кепілі емес
Gitleaks 8.30.1	dir режимі, --redact=100; 0 нәтиже	R12 қолмен табылған мәселе ретінде қалады
Node API тесті	1 тест өтті: каталог, баға, валидация, транзакция, қайта іске қосқанда сақтау	Бар бақылаулар расталды

Trivy: fs --scanners misconfig,secret --skip-check-update --format json. Жергілікті policy cache болмағандықтан embedded checks қолданылды. Бұл іске қосуда vulnerability/CVE сканері, контейнер image сканы және толық SBOM жасалмады. requirements.txt орнатылған пакеттердің нақты күйін дәлелдемейді.

Gitleaks: dir scan-source --redact=100 --report-format json. Стандартты ережелер төмен энтропиялы/демо парольді өткізіп жіберуі мүмкін. app.py:13 паролі кодты қолмен талдаудан R12 ретінде тіркелді; мәні есепке көшірілмеді.

API тестінің алғашқы sandbox әрекеті localhost EACCES қатесімен тоқтады. Жергілікті желіге рұқсатпен қайта орындау сәтті өтті; нәтижесі evidence/api-tests.log ішінде. Restore, XSS немесе жүктеме тесттері осы функционалдық тестпен дәлелденбейді.

Құралдардың түпнұсқалығы

Екі Windows архиві ресми GitHub release-тен жүктелді және сол release checksums.txt файлы бойынша SHA-256 тексерілді. Толық хэштер evidence/tool-integrity.json ішінде. JSON есептері, орындау командалары және логтар evidence каталогында сақталды.

8. Бэклогқа енгізілген шаралар

B7-01 · Деректерді азайту және профильді қауіпсіз көрсету

Басымдық: P0. Жауапты: Зулпыхаров Ерасыл. Мерзім: 19.10.2026. Байланыс: R02,R03,R04,R05.

Жұмыс: Карта өрістерін/сақтауын жою; бұрынғы карта атрибуттарын тазалау; innerHTML мәндерін қауіпсіз DOM тәсіліне ауыстыру; жергілікті тапсырыста PII-ді азайту; саясат/келісім және демо деректі жою рәсімін қосу.

Дайындық критерийі: Синтетикалық ескі профиль жаңарған соң cardNumber/cardExpiry жоқ; HTML тест мәтін болып көрінеді; шығудан кейін сезімтал жергілікті дерек қалмайды; келісім нұсқасы мен уақытын тіркеу; жою сценарийі өтеді.

8 сағат (сараптамалық); мәртебе: жоспарланған.

B7-02 · Тапсырыс API-ін теріс пайдаланудан және қайталаудан қорғау

Басымдық: P0. Жауапты: Зулпыхаров Ерасыл. Мерзім: 22.10.2026. Байланыс: R06,R07,R08.

Жұмыс: 60 секундта 5 тапсырыс шегі; TTL бар бронь/растау; Idempotency-Key сақтау; құпиясыз request ID журналы. Прокси артында IP сенім ережесін нақтылау.

Дайындық критерийі: 6-шы сұрау 429; бір кілтпен қайталау бір ID және бір қор өзгерісі; басқа payload сол кілтпен 409; TTL соңында бронь босайды; журналда телефон/мекенжай жоқ.

8 сағат (сараптамалық); мәртебе: жоспарланған.

8. Бэклогқа енгізілген шаралар

B7-03 · Қалпына келтіру мен deployment қауіпсіздігін тексеру

Басымдық: P1. Жауапты: Зулпыхаров Ерасыл. Мерзім: 26.10.2026. Байланыс: R04,R10,R12,R14,R15.

Жұмыс: R12 бойынша 16.10.2026 дейін пароль қолданылуын анықтау/қажет болса ауыстыру; қорғалған күнделікті SQLite backup; root емес контейнер; digest/тәуелділік есебі; сканерді қайталау.

Дайындық критерийі: Бөлек каталогқа restore ≤30 минут; backup жасы ≤24 сағат; integrity_check=ok және тест тапсырыс саны сәйкес; UID!=0; secret scan қаралған; нәтижелер хаттамаға жазылған.

8 сағат (сараптамалық); мәртебе: жоспарланған.

Қабылдау және бақылау тәртібі

Үш тапсырма docs/backlog-lab7.md файлына енгізілді. Жалпы бастапқы бағалау - 24 сағат. Мерзімдер ұсынылған: 19, 22 және 26 қазан 2026. Бұл жаңа scope бұрынғы жоспарға қосылғандықтан 5/6-апта мерзім болжамын қайта қарау керек; орындалған жұмыс немесе нақты өнімділік ретінде санауға болмайды.

Апта сайын: триггерлерді тексеру → жаңа дәлел тіркеу → P/I қайта бағалау → міндет пен мерзімді жаңарту. Қауіп жабылғанда орындалған өзгеріске сілтеме, тест дәлелі және қалдық баға жазылады. Жоғары қалдық тәуекелді қабылдау туралы шешім тапсырыс берушімен/оқытушымен бекітіледі.

9. Файлдар және қолдану тәртібі

Файл	Мақсаты
GadgetStore_Lab7.pdf	Тапсыруға арналған қазақша есеп
GadgetStore_Lab7.md	Есептің өңделетін мәтіндік нұсқасы
RAID.json	24 толық тәуекел және A/I/D жазбалары
GadgetStore_ThreatDragon.json	OWASP Threat Dragon 2.x моделі
backlog-lab7.md	3 нақты mitigation тапсырмасы
evidence/	Сканер JSON/логтары, manifest және валидация дәлелі

Threat Dragon-да ашу

OWASP Threat Dragon 2.x веб немесе desktop нұсқасын ашу → Local Session / жергілікті файл режимін таңдау → Open an existing threat model → GadgetStore_ThreatDragon.json файлын көрсету → Order data exchange / STRIDE диаграммасын ашу. Интерфейс атаулары нұсқаға қарай сәл өзгеруі мүмкін [5].

Күтілетін нәтиже: 12 элемент және 10 Open қауіп, барлық 6 STRIDE санаты. JSON Schema тексеруі өтті; UI импорт тексеруі Computer Use ағымдағы browser URL-ді сенімді анықтай алмағандықтан орындалмады. Сондықтан модельді қолданбада ашу және команда/оқытушымен қарау - тапсыру алдындағы қалған тексеру.

Ресми дереккөздер · тексерілген күн 15.10.2026

[1] ҚР «Дербес деректер және оларды қорғау туралы» заңы: https://old.adilet.zan.kz/rus/docs/Z1300000094

[2] Дербес деректерді қорғау шараларының қағидалары: https://old.adilet.zan.kz/rus/docs/V2300032810

[3] Дербес деректерді жинау/өңдеу қағидалары: https://old.adilet.zan.kz/rus/docs/V2000021498

[4] European Commission: AI Act: https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

[5] OWASP Threat Dragon documentation: https://www.threatdragon.com/docs/

[6] Trivy filesystem scanning: https://trivy.dev/docs/latest/target/filesystem/

[7] Gitleaks official repository: https://github.com/gitleaks/gitleaks

[8] Threat Dragon v2 schema:
https://github.com/OWASP/threat-dragon/blob/main/td.vue/src/assets/schema/threat-dragon-v2.schema.json